DRAWBRIDGE

XYZ CAPITAL

CLAUDE SECURITY CONTROLS REVIEW

[DATE]

TABLE OF CONTENTS

OVERVIEW 2
THE VALUE OF PERFORMING A CLAUDE ASSESSMENT 2

RISK ASSESSMENT APPROACH 2

SCOPE 3

RISK RATINGS 3

RISK ASSESSMENT FINDINGS 4
SUMMARY 4
RISKS IDENTIFIED 4

OVERVIEW

XYZ Capital ("**XYZ Capital**" or the "**Firm**") has engaged Drawbridge Partners, LLC ("**Drawbridge**") to assess the security controls and configurations in place within the Firm's Claude environment. This assessment will detail existing risks within XYZ Capital's Claude environment, while providing recommendations to enhance the Firm's cybersecurity posture.

THE VALUE OF PERFORMING A CLAUDE ASSESSMENT

Performing a Claude Assessment helps organizations identify cyber security risks that can leave them vulnerable to compromise of critical systems and data. By evaluating the strength of their existing cybersecurity controls, Drawbridge can help reduce risk exposure and prioritize remediation efforts.

Performing a Claude Assessment allows a firm to:

- Identify misconfigured or missing security controls within the Claude environment
- Evaluate the effectiveness of existing security controls
- Implement controls to safeguard confidential data and the systems in which that data is processed, stored, or transmitted
- Safeguard organizations from potential cyber threats which may lead to financial losses
- Reduce cyber-risk
- Meet investor/regulatory requirements

RISK ASSESSMENT APPROACH

Drawbridge's risk assessment approach aligns with the Center for Internet Security standards ("CIS") security controls framework as well as other industry standard frameworks. Drawbridge requested that XYZ Capital provide access to the Firm's Claude environment via screenshare. Drawbridge worked with the organization to assess the environment and identify various risks and strengths within the existing configuration.

The identified risks were assigned a rating to communicate both severity and the order in which each risk should be addressed. The rating criteria is based on the probability of a risk being exploited and the severity of impact that each exploited risk would have on the organization. In addition to risk ratings, recommendations for mitigating or remediating the risks are available for guidance.

SCOPE

For the purposes of the assessment, "confidential data" means any non-public data that could adversely affect XYZ Capital if it were made available to the public. Confidential data includes, but is not limited to:

- Employee or prospective employee data
- Business data
- Investor or prospective investor data
- Client or prospective client data
- Investment data such as, but not limited to:
    - Personally identifiable information, intellectual property, electronic communications, financial records, legal documentation, any data not available to the public, or any other data deemed confidential by XYZ Capital.

RISK RATINGS

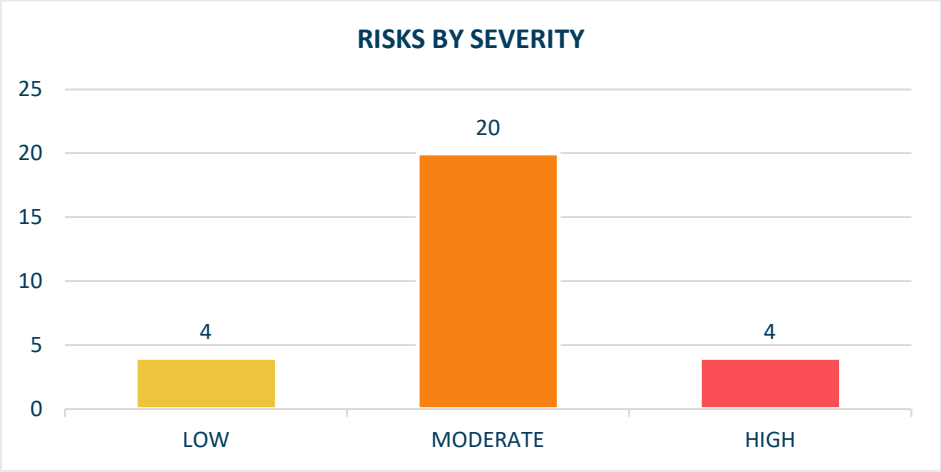
The rating criteria is based on the probability of an incident occurring and the severity of impact the incident would have if the risks were to materialize.

HIGH	High-severity risks are risks that: • Have a high likelihood of causing significant harm to the organization's operations, financial stability, or reputation; • Should be prioritized for remediation, and swift action to mitigate is recommended due to the high likelihood of exploitation; • Exploitation may lead to significant data breaches, widespread systems disruptions, or sizeable financial loss.
MODERATE	Moderate-severity risks are those that: • Could negatively impact the organization but may not pose an immediate threat; • Have a moderate likelihood of occurrence and/or would result in a moderate level of disruption; • Should be addressed in a timely manner to avoid escalation to a higher level of risk, though they should not be prioritized over high-severity findings; • Often include issues that could disrupt non-critical operations.
LOW	Low-severity risks are those that: • Have a minimal impact on the organization if exploited and are often accepted or monitored with minimal mitigation action; • Have a low likelihood of being exploited and/or would lead to minor disruptions; • While not urgent, should be tracked to ensure they do not escalate over time; • Compensating controls often lead to the acceptance of low severity risks, though it is recommended that they be revisited each time an assessment is performed.

RISK ASSESSMENT FINDINGS

SUMMARY

The graph below displays the breakdown of High, Moderate, and Low severity risks Drawbridge identified during the assessment. In addition to risk ratings, recommendations for mitigating or remediating the risks are available for guidance.



RISKS IDENTIFIED

ORGANIZATION			
Severity	**Findings**	**Risk**	**Recommendation**
HIGH	Members are not reviewed regulary to ensure active employees and permissions are properly scoped.	Inadequate member management allows unauthorized individuals to retain access after termination or role changes. Manual member management creates delays in deprovisioning, extending windows for insider threats or compromised accounts.	Implement documented procedures for adding/removing members with approval workflows. Establish automated alerts when members are added or elevated to administrative roles.
Security Controls Currently in Place			
• Administrative access is limited to two to three accounts.			

DATA & PRIVACY			
Severity	**Findings**	**Risk**	**Recommendation**
MODERATE	Connector Chat Sharing is enabled.	Sharing connector-based chats could expose derived insights from sensitive data sources even though raw data isn't visible. Recipients may be able to reverse-engineer sensitive information from Claude's responses about restricted data sources.	Disable connector chat sharing unless absolutely necessary for collaboration workflows. If enabled, implement strict policies requiring data owner approval before sharing connector-based conversations.
LOW	Coarse Location Tracking is enabled.	Location metadata collection creates privacy concerns and may violate user expectations about data minimization. Aggregated location data could reveal organizational presence, travel patterns, or strategic activities in specific regions.	Disable location metadata unless specific product features require it for documented use cases.
Security Controls Currently in Place			
• Public Projects are not visible and accessible to all organization members.			

IDENTITY & ACCESS			
Severity	**Findings**	**Risk**	**Recommendation**
HIGH	Organization creation is not restricted.	Without restrictions, employees can create shadow organizations outside IT visibility and security controls. Shadow organizations bypass corporate policies, audit logging, and data governance requirements.	Enable organization creation restrictions for all verified domains to prevent shadow IT. Monitor for attempts to create unauthorized organizations and address with policy enforcement.
Security Controls Currently in Place			
• SSO is enforced when accessing the firm's Claude environment.			

CAPABILITIES			
Severity	**Findings**	**Risk**	**Recommendation**
MODERATE	Web search is enabled.	Web search queries may expose internal project names, strategic initiatives, or research directions to search providers. Query logs could reveal competitive intelligence or indicate organizational interests in specific topics or technologies.	Disable web search if conversations regularly involve sensitive project names or strategic information. If enabled, train users to avoid including confidential context in prompts that will trigger searches.
Security Controls Currently in Place			
• Cross-Source Search is disabled. • Interactive content is diabled.			

CLAUDE CODE			
Severity	**Findings**	**Risk**	**Recommendation**
HIGH	Bypass permissions mode is allowed.	Bypass mode enables Claude to execute arbitrary commands without oversight, dramatically increasing risk of damage or data loss. Prompt injection attacks could cause Claude to exfiltrate data, modify critical files, or corrupt system state without user knowledge.	Never enable bypass mode in production or for repositories containing sensitive code. If absolutely required for isolated experimentation, limit to sandboxed development environments with no sensitive data and implement extensive monitoring.
MODERATE	Share Claude Code web sessions is enabled.	Shared sessions could expose sensitive code, credentials, or architectural details to unauthorized team members. Session sharing may lack granular access controls, enabling broader visibility than intended by original developer.	Disable session sharing or implement strict policies requiring sanitization of sensitive information before sharing. If enabled, require data owner approval and implement audit logging of all shared sessions.

CLAUDE IN CHROME			
Severity	**Findings**	**Risk**	**Recommendation**
MODERATE	Browser Extension Deployment is enabled.	Uncontrolled browser extension usage could process sensitive web application data without proper governance. Extension permissions may grant broad access to websites and form data beyond what users realize.	Keep disabled until site permissions and policies are fully configured. When enabling, deploy through managed Chrome policies rather than allowing individual installation.

CONNECTORS
Security Controls Currently in Place
• A connector approval and maintenance policy is in place.

SKILLS			
Severity	**Findings**	**Risk**	**Recommendation**
MODERATE	Code execution and file creation is enabled.	Claude can run code and generate files directly in your session, which could potentially execute unintended operations if a malicious prompt tricks Claude into running harmful scripts.	Keep Code Execution and File Creation turned off unless you actively need it for a specific task, then disable it again when done. Always review any code Claude generates before allowing it to run, and avoid pasting untrusted external content (like unknown prompts or scripts) into the conversation while the feature is enabled.

POLICY & PROCESS			
Severity	**Findings**	**Risk**	**Recommendation**
HIGH	Developers do not receive specialized GPT security training.	Developers may unintentionally create insecure GPTs or actions. Sensitive information may be used for training or improvement in ways that are not fully controlled or understood by the organization, leading to unintended data exposure.	Provide targeted training for GPT creators and developers.
HIGH	A formal vendor risk assessment for Anthropic is not documented.	Lacking documented vendor risk assessments makes it harder to demonstrate due diligence around how AI providers handle data and security. This can create compliance gaps third-party risk.	Maintain a completed vendor risk assessment referencing Anthropic security documentation.

COWORK			
Severity	**Findings**	**Risk**	**Recommendation**
HIGH	Access to local files with sensitive information is not restricted.	Cowork's unrestricted access to local files means sensitive information — such as credentials, personal data, or confidential business documents — could be inadvertently exposed or processed without the user's full awareness. This increases the risk of data leakage, especially if Claude interacts with files beyond the intended scope of a given task.	Configure file access permissions to limit Cowork's reach to only the specific folders or file types required for each task, following the principle of least privilege. Regularly audit which directories are accessible and create user prompts or confirmation steps before Claude reads or modifies files containing sensitive information.